FINGERPRINT // 2000DC78D7BE0796

// CONFIDENTIAL STRATEGY //

OMNIPOTENCE ENGAGEMENT ARCHITECTURE

Strategic Nexus

Strategic Security Scoping v33.0 Omni-Review

ENTITY

Nexus Bank

NEXUS SCORE

70%

70

NEXUS INDEX

1.1 Engagement Coverage Index

This score reflects the breadth of technical validation across core governance pillars.

PILLAR	STATUS	PRIORITY
GOV	VALIDATED	Strategic
RES	VALIDATED	Strategic
INT	VALIDATED	Strategic
PRI	GAP	Strategic
SOV	VALIDATED	Strategic
ID	GAP	Strategic

Business Profile & Objectives

PART I.A: BUSINESS CONTEXT

ENGAGEMENT PARAMETER	CLIENT SPECIFICATION
Engagement Description	**DORA-compliant Threat-Led Penetration Testing (TLPT) of core banking systems.**
Primary Deliverable	**Formal TLPT Red Team Execution Log and Remediation Plan.**

1.5 Regulatory Alignment: DORA Bank Resilience

Narrative: DORA resilience and TLPT-ready scoping for critical ICT systems, functions, and third-party ICT dependencies.

REGULATORY BODY — **Digital Operational Resilience Act (DORA) (European Union)**

ARTICLE/REF	TITLE	REQUIREMENT	SCOPING GUIDANCE
Article 24	General Control Testing	ICT resilience testing programme.	Critical ICT systems.
Article 26	TLPT	Threat-led penetration testing.	Every 3 years for critical entities.

Mandatory Evidence Artifacts:

Asset Register | Threat Scenarios | TI Plan | Remediation Plan

IMPLEMENTATION GUIDANCE — **DORA**

ICT Asset Criticality Mapping

Under DORA, scoping must start with the ICT Asset Register. Every asset in scope must be mapped to a 'Critical or Important Function' (CIF). If an asset supports a CIF, it is subject to more rigorous testing and reporting requirements.

Third-Party ICT Risk

DORA requires that testing includes third-party ICT service providers where they support critical or important functions. This scoping pack must include a list of involved third parties and confirmation of their authorization to test.

Threat Intelligence Requirements

For TLPT (Threat-Led Penetration Testing), the scope must be driven by current, relevant threat intelligence. The scenarios defined in this pack should match the TTPs of actors targeting the financial sector.

IMPLEMENTATION GUIDANCE

MITRE

T1190 - Exploit Public-Facing Application

Adversaries may attempt to take advantage of a weakness in an Internet-facing computer or program using software, data, or commands in order to cause unintended or unanticipated behavior.

T1078 - Valid Accounts

Adversaries may obtain and abuse credentials of existing accounts as a means of gaining Initial Access, Persistence, Privilege Escalation, or Defense Evasion.

T1566 - Phishing

Adversaries may send phishing messages to gain access to victim systems. All forms of phishing are electronically delivered social engineering.

T1059 - Command and Scripting Interpreter

Adversaries may abuse command and script interpreters to execute commands, scripts, or binaries.

IMPLEMENTATION GUIDANCE

OWASP

A01:2021-Broken Access Control

Testing must validate that users cannot act outside of their intended permissions. Failures typically lead to unauthorized information disclosure, modification, or destruction of all data.

A02:2021-Cryptographic Failures

Testing must verify the protection of sensitive data in transit and at rest. This includes passwords, credit card numbers, health records, personal information, and business secrets.

A03:2021-Injection

Testing must validate that user-supplied data is not interpreted as commands or queries (e.g., SQL, NoSQL, OS command, ORM, LDAP, and EL expression or OGNL injection).

A04:2021-Insecure Design

Testing must evaluate the architectural design for missing or ineffective control design. Insecure design cannot be fixed by a perfect implementation.

Control 1: Inventory and Control of Enterprise Assets

Actively manage (inventory, track, and correct) all enterprise assets connected to the infrastructure physically, virtually, remotely, and those within cloud environments.

Control 4: Secure Configuration of Enterprise Assets and Software

Establish and maintain the secure configuration of enterprise assets and software.

Control 12: Network Infrastructure Management

Establish, implement, and actively manage network devices, in order to prevent attackers from exploiting vulnerable network services and access points.

Threat Scenarios & Modeling

PART I.C: THREAT INTELLIGENCE

Threat Intelligence Profiles

The following threat actors and attack scenarios have been selected to drive the execution methodology.

THREAT ACTOR	MOTIVATION	TARGET OBJECTIVE	PRIMARY TTPS
APT29 (Cozy Bear)	Espionage and data theft	Exfiltrate customer PII from the core banking database	Spearphishing, Living off the Land, Custom Malware
FIN7	Financial Gain	Compromise SWIFT payment gateways	Supply chain compromise, Ransomware deployment

2.1 Digital Chain of Evidence

Artifacts produced during this engagement follow a cryptographically-verifiable lifecycle.

LIFECYCLE PHASE	VALIDATION METHOD
Acquisition	SHA-256 Verified Capture
Processing	Air-Gapped Analysis Environment
Destruction	NIST 800-88 Compliant Wipe

2.2 Data Sovereignty & Residency

To adhere to regulatory data protection requirements, the following residency rules apply to all engagement artifacts.

FRAMEWORK	RESIDENCY MANDATE
DORA	Must remain strictly within EU boundaries or approved adequate jurisdictions. Cloud storage requires EU-based tenants.

2.3 Regulator Audit & Access Rights

The following audit rights and access privileges are contractually granted to the respective regulatory bodies.

REGULATOR	ACCESS RIGHTS
DORA	European Supervisory Authorities (ESAs) must have full and unrestricted access to threat-led penetration testing results.

Target Scope & Access Readiness

Core Target Register

The following assets are explicitly in-scope for this engagement.

ID	TARGET / GROUP	TYPE	ENVIRONMENT	OWNER
TGT-001	api.nexus-bank.com	API Gateway	Production	Platform Team
TGT-002	10.50.0.0/16	Internal Network Range	Corporate	IT Infrastructure

Access & Test Data Readiness

Required access and data prerequisites.

PREREQUISITE	DESCRIPTION / STATUS
VPN Access	Client to provide OpenVPN profiles for two consultants.

Third-Party ICT Supply Chain Scope

Third-Party ICT Dependency Register

The following third-party service providers (Cloud, SaaS, MSPs) host or manage in-scope assets and require explicit authorization.

PROVIDER	SERVICE TYPE	ASSETS HOSTED	AUTHORIZATION STATUS
AWS	Cloud Infrastructure	EKS Clusters, RDS Databases	Authorized (AWS Acceptable Use)
Okta	Identity Provider	Corporate SSO	Pending Notification

Technical Scope of Work

PT-NET-EXT

External Network Penetration Test

A structured assessment of internet-facing infrastructure including firewalls, VPNs, mail gateways, and publicly reachable hosts. Testers simulate real-world attackers attempting to gain unauthorised access from outside the perimeter. Findings are rated by exploitability and business impact.

2 Days | €3,500 Budgetary ALLOC

PT-NET-INT

Internal Network Penetration Test

Simulates an attacker with initial foothold inside the corporate LAN — whether an insider threat, a compromised workstation, or post-phishing access. The assessment covers lateral movement, privilege escalation, network segmentation effectiveness, and sensitive data exposure.

3 Days | €5,000 Budgetary ALLOC

PT-APP-WEB

Web Application Penetration Test

Manual-led security testing of web applications aligned to the OWASP Top 10 and WSTG, covering injection flaws, broken authentication, sensitive data exposure, XML external entities, broken access control, security misconfigurations, XSS, insecure deserialisation, and business logic vulnerabilities.

3 Days | €4,000 Budgetary ALLOC

PT-APP-API

REST/GraphQL API Security Testing

Targeted assessment of REST, SOAP, and GraphQL APIs using the OWASP API Security Top 10 framework. Covers broken object-level authorisation, excessive data exposure, lack of rate limiting, broken function-level authorisation, mass assignment, security misconfiguration, and injection flaws.

2 Days | €3,500 Budgetary ALLOC

RT-FULL

Full Red Team Engagement

An adversary simulation engagement where a dedicated red team uses realistic threat actor TTPs to attack the organisation across all vectors — digital, physical, and human — without prior disclosure to defenders. Measures the organisation's detection, response, and containment capabilities.

17 Days | €25,000 Budgetary ALLOC

Assessment of cloud-native infrastructure, IAM, and resource configurations.

3 Days | €5,000 Budgetary ALLOC

Omni Control Matrix

PART III.B: OMNI MATRIX

3.1 Omni Control Mapping

The following granular controls are in scope for the selected execution modules.

CONTROL ID	DOMAIN	DESCRIPTION
AC_01	None	None
IA_02	None	None
SI_04	None	None

RACI Governance

PART III.C: RACI MATRIX

3.2 RACI Governance Matrix

Responsibility Assignment Matrix for engagement activities.

ACTIVITY	PROVIDER	CLIENT SEC LEAD	CLIENT IT	CLIENT EXEC
Project Kick-off	**R**	**A**	**C**	**I**
Access Provisioning	**C**	**I**	**R**	**A**
Technical Testing	**R**	**A**	**I**	**C**
Report Delivery	**R**	**A**	**C**	**I**
Remediation Sign-off	**C**	**I**	**R**	**A**

Regulatory Deliverables Schedule

Regulatory Deliverables Schedule

The following reports and evidence logs are contractually required to satisfy the loaded regulatory frameworks.

REGULATORY BODY	MANDATORY DELIVERABLE ARTIFACT
Digital Operational Resilience Act (DORA)	Asset Register
Digital Operational Resilience Act (DORA)	Threat Scenarios
Digital Operational Resilience Act (DORA)	TI Plan
Digital Operational Resilience Act (DORA)	Remediation Plan

Quality Assurance & Peer Review

PART IV.B: QUALITY ASSURANCE

Formal Quality Assurance Gate

Based on the selected regulatory frameworks and execution modules, the following QA routing is algorithmically enforced.

REQUIRED QA LEVEL: TLPT Qualified Red Team Reviewer

Mandatory Threat-Led Penetration Testing (TLPT) review gate. Evidence and kill-chain paths must be validated by a certified Red Team peer reviewer before report release.

Verification & Sign-off

PART V: AUTHORIZATION

NEXUS SEAL

Executive Sponsor Approval

Lead Strategic Provider

FINGERPRINT // 2000DC78D7BE079665369A2FCE847A97A968EDCE49CB20DEA9E09D6311DAB836

Engagement Sign-Off

By signing below, the client agrees that this unified scoping document satisfies the engagement coverage requirements for DORA, FRB, HKMA, and PRA compliance regimes.

Executive Sponsor: _____

Date: _____